

IT 253 Project Two Security Plan – Francisco Sousa

A. Roles and Responsibilities

The following roles are responsible for ensuring the security of the company's e-commerce system. Each role carries specific accountability that together creates a layered ownership of system security.

Information Security Manager

Owns the overall information security plan and is responsible for ensuring it is implemented, maintained, and updated. Oversees vulnerability management, access control reviews, policy compliance, and incident response planning. Reports directly to company leadership and serves as the primary point of contact for all security matters.

System Administrator

Responsible for the day-to-day technical management of WEBSERV01, DBSERV1, and ERP1. Manages server configurations, applies security patches, configures the firewall (FW1), maintains system logs, and performs and verifies backups. Must use individual named accounts; shared accounts are prohibited. Reports to the Information Security Manager.

Database Administrator

Manages DBSERV1, including access controls for the Microsoft SQL 2019 database, data encryption implementation, and user account management. Responsible for ensuring that only authorized applications and personnel can query or modify the database. Coordinates with the System Administrator on backup schedules.

IT Security Analyst

Monitors system and security logs from the centralized SIEM platform, investigates alerts, and reports anomalies to the Information Security Manager. Conducts vulnerability scans on a scheduled basis and tracks remediation progress. Assists with security awareness training delivery.

All Employees

All 850 employees are responsible for following the company's information security policy, completing mandatory security awareness training, reporting suspicious activity or emails to IT,

and protecting their individual login credentials. Employees must never share passwords or allow unauthorized access to company systems.

B. User Awareness Training

The consultant found that employees were unaware of how to handle phishing or suspicious emails, and IT staff were unclear about their security responsibilities. A robust Security Education, Training, and Awareness (SETA) program is essential to address the human layer of security and must go beyond standard new-hire onboarding.

All Employees — Annual Security Awareness Training

All employees must complete a mandatory annual security awareness training program that covers phishing and social engineering recognition, proper handling of sensitive customer data, password hygiene and acceptable use of company systems, how to report security incidents and suspicious activity, and physical security responsibilities such as clean desk policies and tailgating prevention.

IT Staff — Role-Based Technical Training

System administrators, the database administrator, and the IT security analyst must complete additional role-based training relevant to their specific responsibilities. This includes secure server configuration and hardening, firewall management and network security, patch management procedures, vulnerability scanning tools and remediation workflows, and incident response procedures. This training must be completed annually and whenever significant system changes are made.

Simulated Phishing Exercises

The IT Security Analyst will conduct quarterly simulated phishing campaigns targeting all employees to measure training effectiveness and identify individuals who require additional coaching. Results will be reported to the Information Security Manager.

Training completion will be tracked and documented. Employees who fail to complete required training within the designated period will be flagged to their manager, and access to sensitive systems may be suspended until training is completed.

C. Access Control

The current system uses a shared administrator account for DBSERV1, which prevents individual accountability and represents a SOX compliance violation. The following access control policies will govern how accounts are created, managed, and removed across WEBSERV01, DBSERV1, and ERP1.

Account Creation

All accounts must be individually named and tied to a specific employee. Shared accounts are prohibited. Access is granted based on the principle of least privilege each user receives only the permissions required to perform their specific job function. System administrator and database administrator accounts require approval from the Information Security Manager before provisioning. All privileged accounts must use multi-factor authentication (MFA).

Account Review

The Information Security Manager will conduct a formal access review quarterly. During this review, all active accounts across WEBSERV01, DBSERV1, and ERP1 will be verified against current employee roles. Accounts belonging to employees who have changed roles or departments will be adjusted to reflect their new responsibilities. Any access that cannot be justified by current job function will be removed.

Account Termination

When an employee separates from the company, HR must notify IT on the same business day. All system accounts must be disabled within two hours of notification and permanently removed within 24 hours. VNC remote access credentials must be revoked immediately upon separation.

Remote Access

VNC remote management of WEBSERV01 is currently accessible from anywhere in the world without restriction. VNC access must be replaced with SSH for key-based authentication or a VPN-gated remote access solution. Direct internet-facing remote management of production servers is prohibited. All remote access sessions must be logged and reviewed by the IT Security Analyst.

D. Vulnerability Management

The current system has several significant vulnerabilities including an outdated Apache Web Server version (2.2), a firewall with default configurations and all ports open, no encryption on DBSERV1, and no DMZ for WEBSERV01. A structured vulnerability management program will be implemented to identify, prioritize, and remediate weaknesses on an ongoing basis.

Vulnerability Scanning

The IT Security Analyst will conduct automated vulnerability scans of WEBSERV01, DBSERV1, and ERP1 monthly using an industry-standard scanning tool. Scans will check for outdated software versions, missing patches, open ports, misconfigurations, and known exploits. Results will be documented and reported to the Information Security Manager within 48 hours of scan completion.

Prioritization and Remediation

Identified vulnerabilities will be classified by severity; critical, high, medium, and low. Critical and high-severity vulnerabilities must be remediated within 14 days of discovery. Medium vulnerabilities must be addressed within 30 days. Low-severity findings will be scheduled for the next maintenance cycle. The System Administrator is responsible for applying patches and configuration changes. All remediation must be verified and documented.

Immediate Actions Required

- Upgrade Apache Web Server from version 2.2 (end-of-life) to the current supported version
- Reconfigure FW1 to close all unnecessary ports and replace default configurations with a deny-by-default ruleset
- Enable encryption on DBSERV1 for all stored data
- Place WEBSERV01 into a DMZ by adding a second firewall between the web server and the internal network to isolate internet-facing traffic from internal systems

E. Backup and Recovery

Currently, no regular backups are being performed for any of the system servers, and no redundancy is configured. This represents a critical availability risk that directly conflicts with SOX requirements and the company's business continuity objectives. The following backup and recovery plan will be implemented immediately.

Backup Schedule

A full backup of WEBSERV01, DBSERV1, and ERP1 will be performed every Sunday night during a low-traffic maintenance window. Incremental backups are capturing changes since the last

full or incremental backup will run nightly Monday through Saturday. This schedule ensures that the maximum data loss in a recovery scenario is limited to 24 hours of transactions.

Backup Storage and Encryption

All backups must be encrypted using AES-256 for encryption before storage. Backups will be stored in two locations: a local encrypted copy in the Detroit data center for rapid recovery, and a replicated encrypted copy in a geographically separate secure cloud storage environment. Storing backups exclusively on-site, as was previously the case, creates a single point of failure that ransomware or a physical disaster could eliminate entirely.

Backup Verification

The System Administrator must verify that each backup was completed successfully by reviewing backup logs the following morning. A full restoration test will be conducted quarterly on a non-production server to confirm that backups can be successfully recovered within the target recovery time. Results will be documented and reported to the Information Security Manager.

Server Redundancy

To address the complete absence of redundancy, a failover configuration will be introduced for WEBSERV01 and DBSERV1. A secondary virtual web server and database instance will be configured to activate automatically in the event of a primary server failure. ERP1 will be prioritized for redundancy in the next budget cycle. The data center will also require an uninterruptible power supply (UPS) and generator backup, as identified in Project One, to prevent server failure during power outages.

F. Internet-Facing Security

WEBSERV01 is the company's primary customer-facing system and is directly exposed to the internet. Its current configuration creates significant security risks: the firewall FW1 is set to default with all ports open, the server is not in a DMZ, and remote administration is performed via VNC without access restrictions. These weaknesses expose not only the web server but the internal network behind it. The following controls will secure the internet-facing portion of the system.

DMZ Implementation

WEBSERV01 must be relocated into a properly configured DMZ. A second firewall (FW2) will be added between the web server and the internal network containing DBSERV1 and ERP1. This architecture ensures that even if WEBSERV01 is compromised, an attacker cannot directly access the internal database or ERP systems. FW1 will control traffic between the internet and the DMZ, and FW2 will control traffic between the DMZ and the internal network. Both firewalls will be configured with explicit allow rules and a deny-all default policy.

Firewall Hardening

FW1's default configuration must be replaced immediately. Only ports 443 (HTTPS) and 80 (HTTP, redirected to HTTPS) will be permitted inbound from the internet to WEBSERV01. All other inbound ports will be blocked. Outbound traffic rules will also be reviewed and tightened. All firewall rule changes must follow the change control process and be documented.

HTTPS and TLS Encryption

All customer traffic to the online store must be encrypted using TLS 1.2 or higher. HTTP connections will automatically redirect to HTTPS. A valid SSL/TLS certificate from a trusted certificate authority will be installed on WEBSERV01 and renewed before expiration. Customers transmitting payment and personal information must always be communicating over an encrypted channel.

Intrusion Detection System

A network-based Intrusion Detection System (IDS) will be deployed to monitor traffic entering and exiting the DMZ. The IDS will alert the IT Security Analyst of suspicious activity such as port scanning, unusual request volumes, or known attack signatures. Alerts will be reviewed daily and escalated to the Information Security Manager when warranted.

Web Application Security

Apache Web Server 2.2 is end-of-life and no longer receives security updates. It must be upgraded to a current supported version immediately. Additionally, a Web Application Firewall (WAF) will be deployed in front of WEBSERV01 to filter and monitor HTTP/HTTPS traffic for common web application attacks such as SQL injection and cross-site scripting (XSS), which represent significant risks given that the web server connects directly to DBSERV1.

References

- National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>
- Whitman, M. E., & Mattord, H. J. (2021). Principles of information security (7th ed.). Cengage Learning.